



UNIVERSITAT D'ANDORRA

TREBALL FINAL de CARRERA

Curs 2025 2026

Per optar al títol de

Bàtxelor en informàtica

Títol del Treball Final en anglès

Autor/a

Pere Roca Rubio

Tutors/es

Jan Sau Batlle, Josep Ribó Ferriz

Sant Julià de Lòria, XX de juny 2026

Índex de continguts

Definició breu del projecte i objectius	4
1. Pla de treball.....	5
1.1 Context i justificació	5
1.2 Objectius.....	5
1.3 Objectius de Desenvolupament Sostenible.....	5
1.4 Enfocament i mètode	6
1.5 Planificació	6
1.6 Productes finals	7
1.7 Recursos	7
1.8 Anàlisi de riscos	8
1.9 Estructura de la memòria	8
2. Anàlisi	9
2.1 Problemàtica	9
2.2 Estat de l'art.....	9
2.3 Objectius tècnics	10
2.4 Requisits tècnics	10
3. Disseny	11
3.1 Arquitectura	11
3.2 Components	12
3.3 Altres dissenys	13
Desenvolupament realitzat fins ara.....	14
Implementació de la infraestructura amb Docker	14
Configuració de la xarxa segmentada.....	14
Flux funcional validat.....	14
Primera prova de simulació d'atac	15
Generació de logs i evidències	15
Evidències del progrés.....	15
Incidències i decisions tècniques	17
Errors en la configuració de volums	17
Problemes de connectivitat entre xarxes	17
Simplificació de l'arquitectura	17
Planificació actualitzada	17
4 Implementació	18
4.1 Arquitectura	18

4.2 Components	20
4.2.1 Attack Panel	20
4.2.2 Sistema de nivells de defensa.....	21
4.2.3 Reverse Proxy NGINX.....	22
4.2.4 Detector d'atacs.....	25
4.2.5 Sistema de monitorització.....	26
4.3 Desenvolupament i execució.....	27
4.3.1 Entorn de desenvolupament	27
4.3.2 Execució del sistema.....	28
5 Proves	28
5.1 Definició.....	28
5.2 Avaluació de requisits.....	31
5.3 Avaluació d'objectius.....	31

Definició breu del projecte i objectius

Aquest Treball Final de Bàtxelor consisteix en el desenvolupament d'una **eina educativa per a la simulació de ciberatacs i mecanismes de defensa**, basada en una infraestructura virtualitzada mitjançant contenidors Docker.

L'objectiu principal del projecte no és crear un sistema de ciberseguretat avançat orientat a entorns professionals, sinó una plataforma **didàctica, visual i fàcil d'utilitzar**, pensada per a fer-la servir a les sessions lectives a classe per a estudiants que estiguin aprenent aquests conceptes.

Aquesta eina permetrà reproduir diferents escenaris d'atac de forma controlada (com escaneig de ports, injecció SQL o atacs de força bruta) i observar, en temps real, com reacciona el sistema davant aquests comportaments.

Un dels aspectes clau del projecte és la seva orientació pedagògica. Per aquest motiu, es posa especial èmfasi en:

- La visualització clara dels resultats
- La simplificació dels conceptes tècnics
- La interpretació intuïtiva de les dades

Mitjançant dashboards interactius (Grafana), els usuaris podran veure de forma clara:

- Quins atacs s'estan produint
- Com es detecten
- Quin impacte tenen
- Com els mecanismes de defensa els mitiguen

A més, el sistema permetrà configurar diferents nivells de protecció (sense defensa, defensa bàsica i defensa avançada), facilitant la comparació directa entre un sistema vulnerable i un sistema protegit.

En conjunt, el projecte pretén convertir conceptes complexos de ciberseguretat en experiències visuals i comprensibles, millorant així l'aprenentatge en entorns educatius.

1. Pla de treball

1.1 Context i justificació

La ciberseguretat és un àmbit cada vegada més rellevant dins del sector tecnològic, tant a nivell professional com educatiu. Tot i això, la seva comprensió sovint resulta complexa per a persones sense coneixements tècnics previs, ja que els conceptes implicats són abstractes i difícils de visualitzar.

En l'àmbit docent, aquesta dificultat es tradueix en una manca d'eines pràctiques que permetin mostrar de forma clara i entenedora què ocorre durant un ciberatac i com els sistemes de defensa reaccionen davant d'aquestes situacions.

Actualment, moltes eines de simulació són massa complexes, requereixen infraestructures avançades o estan orientades a perfils professionals, fet que limita el seu ús en contextos educatius inicials.

Davant d'aquesta problemàtica, aquest treball se centra en el desenvolupament d'una eina educativa basada en contenidors Docker que permeti simular ciberatacs i mecanismes de defensa de forma controlada, visual i reproduïble.

1.2 Objectius

Objectiu general

Desenvolupar una plataforma educativa que permeti visualitzar i comparar el comportament d'una infraestructura informàtica davant diferents ciberatacs, amb diversos nivells de defensa activats.

Objectius específics

- Dissenyar una arquitectura de xarxa segmentada basada en contenidors Docker.
- Implementar una infraestructura simulada amb un atacant, una aplicació web vulnerable i una base de dades.
- Integrar mecanismes de monitoratge i visualització (Prometheus, Grafana, Loki).
- Simular escenaris d'atac com escaneig de ports, injecció SQL i força bruta.
- Implementar diferents nivells de defensa configurables.
- Permetre la visualització dels resultats mitjançant dashboards comprensibles per a usuaris no tècnics.

1.3 Objectius de Desenvolupament Sostenible

Aquest projecte té un impacte principalment positiu en diversos Objectius de Desenvolupament Sostenible (ODS):

Impacte positiu

- **ODS 4: Educació de qualitat**
El projecte contribueix a millorar l'aprenentatge en ciberseguretat mitjançant una eina pràctica i visual.

- **ODS 9: Indústria, innovació i infraestructura**

Fomenta el desenvolupament de solucions tecnològiques innovadores en l'àmbit de la seguretat informàtica.

Impacte neutre

- El projecte no té un impacte directe en aspectes mediambientals o socials més amplis.

Impacte negatiu

- No s'identifiquen impactes negatius rellevants, ja que es tracta d'un entorn controlat amb finalitats educatives.

1.4 Enfocament i mètode

El projecte es basa en la creació d'un nou producte software, consistent en una plataforma de simulació de ciberseguretat.

L'enfocament adoptat és incremental i iteratiu, permetent desenvolupar progressivament la infraestructura i validar-ne el funcionament en cada etapa.

La metodologia seguida és de tipus àgil, amb iteracions successives que inclouen:

- definició de requisits
- disseny de l'arquitectura
- implementació dels components
- proves i validació

Aquest enfocament permet adaptar el desenvolupament a possibles incidències i assegurar un progrés continu del projecte.

1.5 Planificació

El projecte s'ha planificat segons el calendari establert per l'assignatura:

- 12 febrer: sessió inicial
- 22 febrer: lliurament del pla de treball
- 22 març: primer seguiment
- 17 maig: segon seguiment
- 31 maig: prelliurament de la memòria
- 9 juny: lliurament final de la memòria
- 14 juny: presentació
- 19 juny: defensa

El desenvolupament es divideix en les següents fases:

1. Anàlisi i definició del sistema
2. Disseny de l'arquitectura

3. Implementació de la infraestructura base
4. Integració de sistemes de monitoratge
5. Implementació d'escenaris d'atac
6. Implementació de mecanismes de defensa
7. Desenvolupament de dashboards
8. Validació i proves
9. Redacció de la memòria

(S'haurà d'incloure un diagrama de Gantt en l'annex)

1.6 Productes finals

Els productes finals del projecte seran:

- Una infraestructura funcional basada en Docker Compose
- Un conjunt d'escenaris d'atac simulats
- Un sistema de defensa configurable per nivells
- Dashboards de visualització amb Grafana
- Documentació tècnica completa del sistema
- Memòria final del treball

1.7 Recursos

Recursos tècnics

- Ordinador personal amb Docker instal·lat
- Sistema operatiu Linux (Ubuntu / WSL2)
- Docker i Docker Compose
- Eines de monitoratge (Prometheus, Grafana, Loki)
- Eines de seguretat (Suricata, Kali Linux)

Recursos humans

- Autor del projecte
 - Pere Roca Rubio
- Tutors acadèmics
 - Jan Sau Batlle
 - Josep Ribó Ferriz

1.8 Anàlisi de riscos

Risc	Impacte	Mitigació
Problemes amb Docker o xarxes	Alt	Simplificar arquitectura
Integració de serveis complexa	Mitjà	Desenvolupament incremental
Falta de temps	Alt	Prioritzar funcionalitats clau
Error en configuració	Mitjà	Validació contínua

1.9 Estructura de la memòria

La memòria s'organitza en els següents capítols:

- **Capítol 2: Anàlisi** → Definició del problema i estat de l'art
- **Capítol 3: Disseny** → Arquitectura i components del sistema
- **Capítol 4: Implementació** → Desenvolupament tècnic
- **Capítol 5: Proves** → Validació del sistema
- **Capítol 6: Evolució** → Distribució i manteniment
- **Capítol 7: Conclusions** → Anàlisi crítica del projecte

2. Anàlisi

2.1 Problemàtica

Actualment, l'aprenentatge de la ciberseguretat presenta diverses dificultats, especialment per a usuaris sense coneixements tècnics previs. Els conceptes associats als ciberatacs i als mecanismes de defensa solen ser abstractes i difícils de visualitzar, cosa la qual dificulta la seva comprensió en entorns educatius.

La majoria d'eines disponibles per a la simulació de ciberseguretat estan orientades a entorns professionals o requereixen una infraestructura complexa, limitant el seu ús en contextos docents inicials. Això provoca que molts estudiants no puguin observar de manera clara què ocorre realment durant un atac o com respon un sistema davant d'aquest.

A més, sovint es presenta informació massa tècnica (logs complexos, alertes difícils d'interpretar), que no és adequada per a persones sense experiència.

Davant d'aquesta situació, es detecta la necessitat d'una eina que permeti:

- Simular atacs de manera controlada
- Visualitzar els resultats de forma clara
- Facilitar la comprensió dels conceptes bàsics

Aquest projecte pretén donar resposta a aquesta necessitat mitjançant una plataforma educativa simplificada i visual.

2.2 Estat de l'art

En l'àmbit de la ciberseguretat, existeixen diverses eines i entorns de simulació com laboratoris virtuals, plataformes de pentesting o entorns de pràctiques. Aquestes solucions permeten realitzar atacs i analitzar sistemes, però acostumen a estar orientades a usuaris amb coneixements tècnics una mica més avançats.

També existeixen sistemes de monitoratge i detecció com Prometheus, Grafana o Suricata, que permeten recollir dades i detectar comportaments anormals. Tot i això, aquestes eines no estan dissenyades específicament amb una finalitat educativa simplificada.

En els darrers anys, l'ús de contenidors Docker ha facilitat la creació d'entorns reproduïbles i aïllats, fet que els converteix en una solució adequada per a laboratoris educatius.

No obstant això, es detecta una manca d'eines que integrin:

- Simulació d'atacs
- Mecanismes de defensa
- Visualització simplificada

Tot en un únic sistema orientat a la docència.

2.3 Objectius tècnics

Els objectius tècnics del projecte són els següents:

- Implementar una infraestructura de serveis mitjançant contenidors Docker
- Definir una arquitectura de xarxa segmentada (attacker, DMZ, internal, monitoring)
- Desplegar una aplicació web vulnerable amb base de dades associada
- Integrar un sistema de monitoratge amb Prometheus i Grafana
- Centralitzar logs mitjançant Loki i Promtail
- Implementar un sistema de detecció d'intrusions amb Suricata
- Desenvolupar escenaris d'atac (port scanning, SQL injection, força bruta)
- Implementar un sistema de configuració de nivells de defensa
- Visualitzar els resultats mitjançant dashboards entenedors

2.4 Requisits tècnics

Requisits funcionals

- El sistema ha de permetre simular ciberatacs des d'un contenidor atacant
- El sistema ha de registrar i visualitzar els esdeveniments generats
- El sistema ha de permetre configurar diferents nivells de defensa
- El sistema ha de mostrar informació clara i comprensible per a usuaris no tècnics
- El sistema ha de permetre comparar diferents escenaris

Requisits no funcionals

- El sistema ha de ser reproduïble mitjançant Docker Compose
- El sistema ha de ser fàcil d'instal·lar i executar
- El sistema ha de tenir una arquitectura modular
- El sistema ha de ser estable durant les simulacions

Requisits operacionals

- Ha de funcionar en entorns Linux o equivalents (WSL2)
- Ha de requerir únicament Docker i Docker Compose
- Ha de poder executar-se en un ordinador personal

3. Disseny

3.1 Arquitectura

El sistema es basa en una arquitectura modular composta per diversos components que interactuen entre ells mitjançant una xarxa segmentada.

Els principals blocs són:

- Atacant (Kali Linux)
- Reverse proxy (Nginx)
- Aplicació web
- Base de dades
- Sistema de detecció (Suricata)
- Sistema de monitoratge (Prometheus, Grafana)
- Sistema de logs (Loki, Promtail)

El funcionament general del sistema és el següent:

Atacant → Reverse Proxy → WebApp → Base de dades
↓
Monitoratge i detecció

La segmentació de xarxa es divideix en:

- attacker_net
- dmz_net
- internal_net
- monitoring_net

Aquest disseny permet separar els diferents nivells de la infraestructura i simular un entorn real simplificat.

3.2 Components

Atacant (Kali Linux)

Simula l'origen dels ciberatacs.

Permet executar eines com nmap, sqlmap o scripts personalitzats.

Reverse Proxy (Nginx)

Actua com a punt d'entrada al sistema (DMZ).

Gestiona el trànsit entrant i permet aplicar mecanismes de defensa com:

- filtratge
- rate limiting
- bloqueig de peticions

Aplicació web

Servei vulnerable dissenyat per ser objectiu dels atacs.

Inclou funcionalitats com formularis o consultes que poden ser explotades.

Base de dades

Sistema de persistència (MariaDB).

Accessible només des de la xarxa interna.

Suricata (IDS)

Sistema de detecció d'intrusions que analitza el trànsit de xarxa i genera alertes.

Prometheus

Recull mètriques del sistema i permet analitzar el comportament dels serveis.

Grafana

Proporciona dashboards visuals per mostrar:

- Activitat d'atacs
- Alertes
- Estat del sistema

Loki + Promtail

Sistema de centralització de logs que permet consultar i visualitzar registres.

3.3 Altres dissenys

Nivells de defensa

El sistema incorpora un mecanisme de configuració basat en una variable:

DEFENSE_LEVEL=apagat | basic | avançat

Aquesta variable permet modificar el comportament del sistema i comparar diferents escenaris segons la seva defensa.

Enfocament educatiu

El disseny del sistema prioritza:

- La simplicitat
- La visualització
- La comprensió dels resultats

Els dashboards es dissenyen amb missatges interpretables, com:

- “Escaneig de ports detectat”
- “Intent d’injecció SQL detectat”
- “Atac bloquejat pel sistema”

Desenvolupament realitzat fins ara

Implementació de la infraestructura amb Docker

S'ha creat una arquitectura basada en **Docker Compose**, amb l'objectiu de definir i desplegar tots els serveis de manera centralitzada i reproduïble.

Els serveis actualment implementats són:

- Contenedor atacant (Kali Linux)
- Reverse proxy (Nginx)
- Aplicació web vulnerable
- Base de dades (MariaDB)
- Sistema de monitoratge:
 - Prometheus
 - Grafana
 - Loki + Promtail
- Sistema de detecció:
 - Suricata

Aquesta infraestructura es desplega mitjançant un únic fitxer `docker-compose.yml`, facilitant la seva execució i replicació.

Configuració de la xarxa segmentada

S'han definit diverses xarxes virtuals per simular una infraestructura real:

- `attacker_net` → xarxa de l'atacant
- `dmz_net` → zona exposada (reverse proxy i web)
- `internal_net` → serveis interns (base de dades)
- `monitoring_net` → sistemes de monitoratge

Aquesta segmentació permet separar els diferents components i preparar l'escenari per a la simulació de ciberatacs.

Flux funcional validat

S'ha validat correctament el flux principal del sistema:

Navegador → Reverse Proxy (Nginx) → Aplicació web → Base de dades

S'ha pogut accedir a l'aplicació web mitjançant:

`http://localhost:8080`

Els logs generats per Nginx confirmen la correcta recepció i processament de peticions HTTP.

Primera prova de simulació d'atac

S'ha realitzat una primera prova d'atac des del contenidor Kali mitjançant l'eina nmap.

Inicialment, es va detectar una incidència relacionada amb la resolució de noms entre contenidors, ja que el contenidor atacant no compartia xarxa amb el reverse proxy.

Aquest problema ha permès validar la importància de la configuració de xarxes en Docker i ha servit per ajustar l'arquitectura per permetre la comunicació necessària entre l'atacant i la DMZ.

Generació de logs i evidències

S'han generat logs reals del sistema, especialment:

- Logs d'accés del reverse proxy (Nginx)
- Logs d'error de Nginx
- Registres de connexions HTTP

Exemple de log d'accés:

```
172.19.0.1 - - [17/Mar/2026:19:30:59 +0000] "GET / HTTP/1.1" 200
```

Aquestes evidències demostren que el sistema és capaç de:

- Rebre peticions
- Processar-les correctament
- Registrar l'activitat

Evidències del progrés

Per tal de demostrar l'estat actual del projecte, es poden incloure les següents evidències:

- Execució dels contenidors (docker compose ps)
- Accés funcional a la web (localhost:8080)
- Logs generats per Nginx
- Estructura del projecte implementada
- Fitxer docker-compose.yml

CONTAINER ID	IMAGE	COMMAND	CREATED	STATUS	PORTS	NAMES
b30910ec51a5	tfb-pereroca-reverse-proxy	"/docker-entrypoint..."	56 seconds ago	Up 55 seconds	0.0.0.0:8080->80/tcp, [::]:8080->80/tcp	reverse-proxy
e5052f0cb1e0	tfb-pereroca-webapp	"/docker-php-entrypoi..."	58 seconds ago	Up 55 seconds	80/tcp	webapp
73617872fc22	tfb-pereroca-kali	"/bin/bash"	58 seconds ago	Up 55 seconds		kali
2d7577f899b3	grafana/grafana:latest	"/run.sh"	4 days ago	Up 2 minutes	0.0.0.0:3000->3000/tcp, [::]:3000->3000/tcp	grafana
006b6525d8cc	prom/prometheus:latest	"/bin/prometheus --c..."	4 days ago	Up 2 minutes	0.0.0.0:9090->9090/tcp, [::]:9090->9090/tcp	prometheus
ae1b2270fd6b	grafana/loki:2.9.8	"/usr/bin/loki -conf..."	4 days ago	Up 2 minutes	0.0.0.0:3100->3100/tcp, [::]:3100->3100/tcp	loki
48997d3c06a1	mariadb:11	"/docker-entrypoint.s..."	4 days ago	Up 2 minutes	3306/tcp	db
9005430cf0df	jasonish/suricata:latest	"/docker-entrypoint..."	4 days ago	Up 2 minutes		suricata
01e69b0e126e	grafana/promtail:2.9.8	"/usr/bin/promtail -..."	4 days ago	Up 2 minutes		promtail



PereTFB Demo

Aplicació web vulnerable en desenvolupament.

```
logs > nginx > access.log
1 172.19.0.1 - - [17/Mar/2026:19:30:59 +0000] "GET / HTTP/1.1" 200 93 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
2 172.19.0.1 - - [17/Mar/2026:19:30:59 +0000] "GET /favicon.ico HTTP/1.1" 404 311 "http://localhost:8080/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
3 172.19.0.1 - - [17/Mar/2026:19:48:10 +0000] "GET / HTTP/1.1" 200 93 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
4 172.19.0.1 - - [22/Mar/2026:15:30:51 +0000] "GET / HTTP/1.1" 200 93 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
5 172.19.0.1 - - [22/Mar/2026:15:30:51 +0000] "GET /favicon.ico HTTP/1.1" 404 311 "http://localhost:8080/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
6 172.19.0.1 - - [22/Mar/2026:15:31:24 +0000] "GET / HTTP/1.1" 200 92 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
7
```

(Aquí deixo un enllaç al Repositori GitHub perquè ho pogueu revisar, on trobareu l'estructura del projecte i el docker-compose.yml, per tal de no emplenar massa amb tanta ScreenShot)

<https://github.com/PereRR/TFBPere>

Incidències i decisions tècniques

Durant el desenvolupament inicial s'han identificat diverses incidències i decisions rellevants:

Errors en la configuració de volums

Es va detectar un error en la configuració de rutes en Docker Compose, concretament una discrepància entre extensions de fitxers (.yaml vs .yml), que impedia l'arrencada correcta del reverse proxy.

Aquest problema es va solucionar ajustant les rutes dels volums, afegint correctament l'extensió dels fitxers, que encara que siguin les mateixes, al ser-hi escrites de manera diferent, les rutes no coincidien amb els fitxers.

Problemes de connectivitat entre xarxes

Inicialment, el contenidor atacant no podia accedir al reverse proxy degut a la separació de xarxes.

Aquesta incidència va permetre identificar la necessitat de definir correctament els punts de connexió entre xarxes per simular escenaris reals.

Es va solucionar afegint temporalment el contenidor Kali dins de la mateixa xarxa que el reverse proxy com a solució temporal. Això es canviarà afegint un firewall en un futur, ja que no és lògic que l'atacant i el reverse proxy hi siguin a la mateixa xarxa.

Simplificació de l'arquitectura

S'ha decidit utilitzar Docker Compose en lloc de solucions més complexes com Kubernetes, amb l'objectiu de garantir la viabilitat del projecte dins del temps disponible, i que és una eina de la qual tinc més coneixements i soltura a l'hora de treballar-ne.

Planificació actualitzada

Per al següent període (fins al segon seguiment), es preveu:

- Implementar completament el sistema de monitoratge
- Integrar Suricata per a la detecció d'atacs
- Desenvolupar el primer escenari funcional (port scanning)
- Crear els primers dashboards en Grafana
- Implementar el sistema de nivells de defensa

Disposar d'un sistema capaç de:

- Executar un atac real des de Kali (3 atacs)
- Detectar-lo mitjançant el sistema
- Visualitzar-lo en un dashboard
- Script funcional per canviar de nivells de seguretat
- Scripts per iniciar/tancar els contenidor

- Windows
- Linux

4 Implementació

4.1 Arquitectura

La implementació del projecte s'ha desenvolupat mitjançant una arquitectura modular basada en contenidors amb Docker, amb l'objectiu de simular un entorn realista de detecció i monitorització d'atacs web.

La solució integra diferents components independents que cooperen entre ells per representar el cicle complet d'un atac: execució, registre, detecció, processament i visualització.

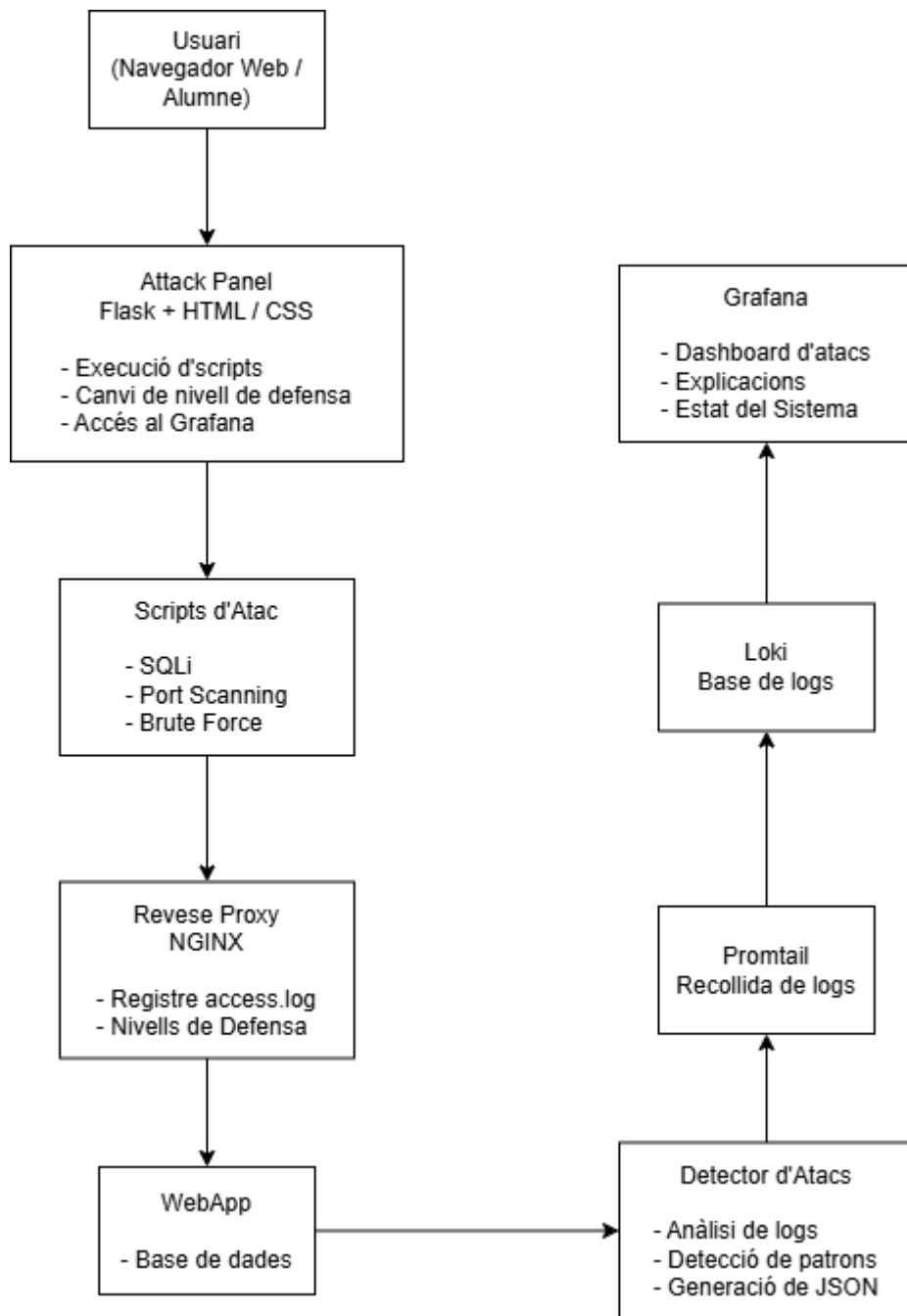
Els components principals de la infraestructura són:

- **Attack Panel (Flask):** interfície web per executar atacs i gestionar els nivells de defensa.
- **Scripts d'atac:** simulacions de SQL Injection, Brute Force i Port Scanning.
- **Reverse Proxy NGINX:** punt d'entrada de les peticions HTTP i generador dels logs.
- **WebApp vulnerable:** aplicació objectiu dels atacs.
- **Detector d'atacs:** script encarregat d'analitzar els logs i generar alertes.
- **Promtail:** recollidor de logs.
- **Loki:** sistema d'emmagatzematge i indexació de logs.
- **Grafana:** dashboard visual per a la monitorització dels atacs.

El flux de funcionament general del sistema és el següent:

1. L'usuari executa un atac des del menú web.
2. El script envia peticions contra la web vulnerable.
3. NGINX registra les peticions als fitxers de logs.
4. El detector analitza els logs i identifica patrons sospitosos.
5. Les alertes es transformen en registres JSON estructurats.
6. Promtail envia els logs a Loki.
7. Grafana mostra visualment les deteccions i les explicacions dels atacs.

Aquest flux d'informació permet representar de manera visual i educativa el cicle complet d'un atac, des de la seva execució fins a la seva detecció i visualització.



4.2 Components

4.2.1 Attack Panel

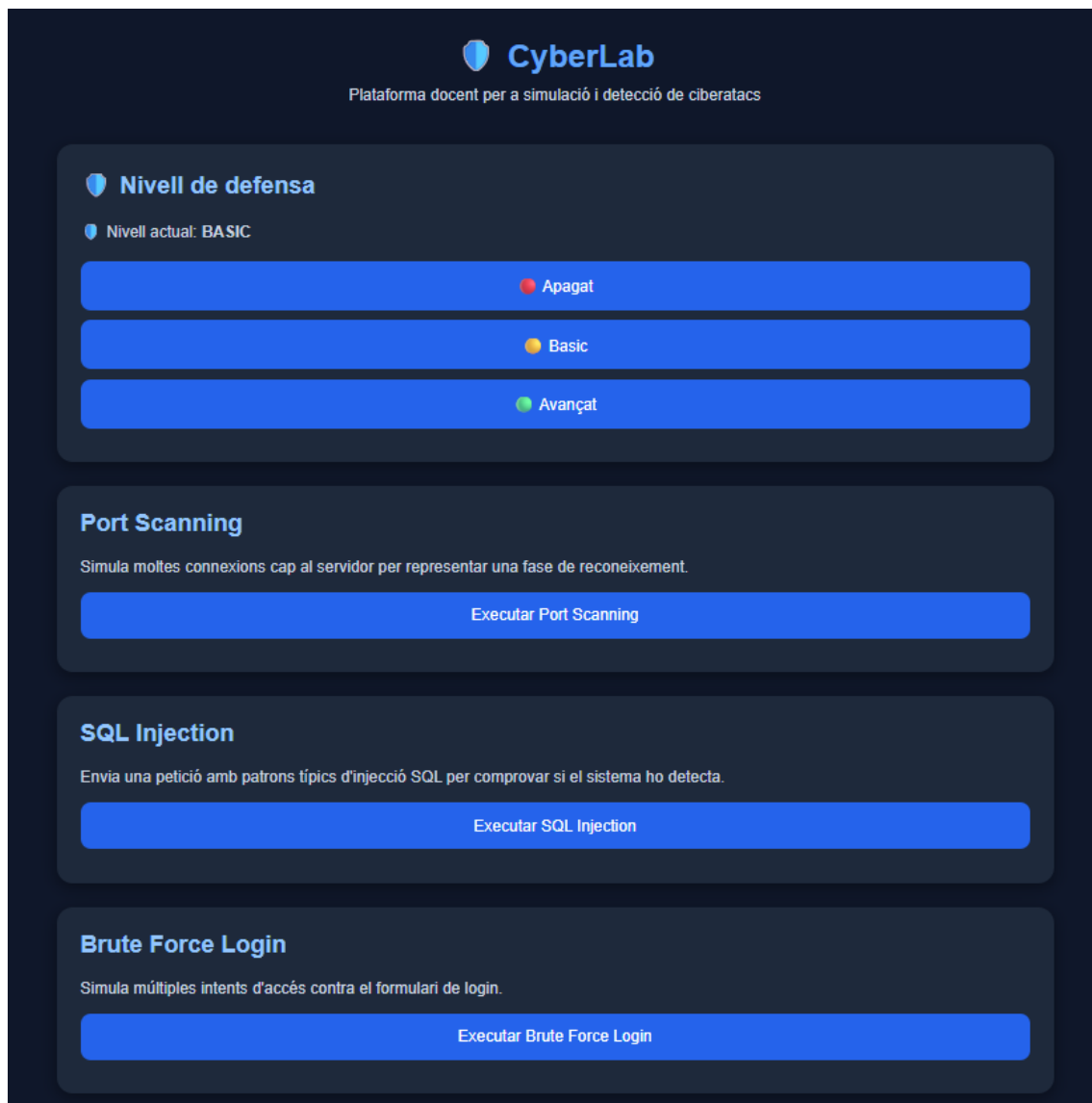
L'Attack Panel és una aplicació web desenvolupada amb Flask que permet centralitzar la interacció amb el laboratori.

La interfície ofereix dues funcionalitats principals:

- Execució visual dels scripts d'atac.
- Configuració dinàmica dels nivells de defensa.

L'objectiu principal és facilitar l'ús del sistema a estudiants sense experiència avançada en línia de comandes.

La interfície s'ha desenvolupat utilitzant HTML i CSS integrats dins l'aplicació Flask.



La plataforma permet executar els atacs directament des del navegador, evitant l'ús manual de terminals.

Quan l'usuari executa un atac:

1. Flask invoca el script corresponent.
2. El script genera peticions HTTP.
3. Les peticions són registrades per NGINX.
4. El detector processa els logs.
5. Grafana actualitza automàticament els dashboards.

4.2.2 Sistema de nivells de defensa

El sistema implementa tres nivells de defensa:

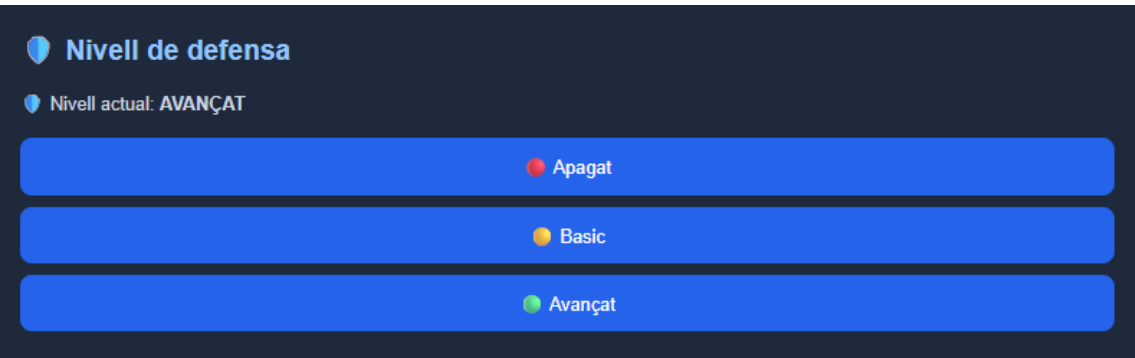
Nivell	Comportament
APAGAT	Sistema vulnerable i detecció mínima
BASIC	Detecció estàndard
AVANÇAT	Detecció agressiva i explicacions tècniques

Cada nivell modifica:

- Sensibilitat dels patrons de detecció.
- Nombre mínim de peticions sospitoses.
- Profunditat de les explicacions mostrades.
- Configuració del reverse proxy.

Els diferents nivells de defensa modifiquen tant la sensibilitat de detecció com el nivell de detall tècnic mostrat a l'usuari.

La configuració es realitza mitjançant un script Bash que modifica dinàmicament la configuració activa del sistema.



4.2.3 Reverse Proxy NGINX

NGINX actua com a reverse proxy entre els scripts d'atac i l'aplicació vulnerable.

Les seves funcions principals són:

- Rebre totes les peticions HTTP.
- Registrar les connexions a access.log.
- Aplicar configuracions segons el nivell de defensa.
- Centralitzar el trànsit del laboratori.

La configuració es modifica dinàmicament segons el nivell seleccionat per l'usuari.

Nivell apagat:

El nivell apagat representa un entorn vulnerable amb proteccions mínimes, on les peticions malicioses poden arribar al servidor sense restriccions significatives. L'objectiu és permetre que els atacs arribin lliurement a l'aplicació per facilitar la demostració de vulnerabilitats.

Característiques principals:

- Reverse proxy sense limitacions de trànsit.
- Sense bloqueig de patrons sospitosos.
- Sense proteccions específiques contra SQL Injection o Brute Force.
- Registre complet de peticions HTTP.

Aquest nivell permet observar el comportament d'un sistema pràcticament sense defenses.

```
pere_roca@DESKTOP-LBRBDFN:/mnt/c/Users/Pere_Roca/Desktop/UNI/TERCERO/TFB$ cat configs/nginx/active.conf
server {
    listen 80;
    server_name _;

    access_log /var/log/nginx/access.log;
    error_log /var/log/nginx/error.log;

    location / {
        proxy_pass http://webapp:80;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    }
}
```

Nivell basic:

El nivell basic introdueix proteccions bàsiques orientades a limitar comportaments sospitosos senzills.

Característiques principals:

- Limitació de peticions HTTP mitjançant limit_req.
- Restricció bàsica del volum de connexions.
- Detecció estàndard d'atacs coneguts.
- Reducció parcial de l'impacte de Brute Force i Port Scanning.

Aquest nivell representa una configuració de seguretat habitual en entorns senzills amb mecanismes de protecció moderats.

```
pere_roca@DESKTOP-LBRBDFN:/mnt/c/Users/Pere_Roca/Desktop/UNI/TERCERO/cat configs/nginx/active.conf
limit_req_zone $binary_remote_addr zone=basic_limit:10m rate=10r/s;

server {
    listen 80;
    server_name _;

    access_log /var/log/nginx/access.log;
    error_log /var/log/nginx/error.log;

    location / {
        limit_req zone=basic_limit burst=20 nodelay;

        proxy_pass http://webapp:80;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    }
}
```

Nivell avançat:

El nivell avançat activa proteccions agressives, aplica controls preventius sobre el trànsit HTTP i mecanismes de detecció més estrictes per reduir l'exposició davant atacs web habituals.

Característiques principals:

- Limitació estricta de peticions HTTP.
- Bloqueig de patrons sospitosos relacionats amb SQL Injection.
- Capçaleres HTTP de seguretat.
- Restriccions específiques sobre el formulari de login.
- Detecció més sensible i detallada.

Aquest nivell simula un entorn amb polítiques de seguretat reforçades i mecanismes preventius més avançats.

```
pere_roca@DESKTOP-LBRBDFN:/mnt/c/Users/Pere_Roca/Desktop/UNI/TERCERO/TFB$ cat configs/nginx/active.conf
limit_req_zone $binary_remote_addr zone=advanced_limit:10m rate=3r/s;

server {
    listen 80;
    server_name _;

    access_log /var/log/nginx/access.log;
    error_log /var/log/nginx/error.log;

    add_header X-Frame-Options "DENY" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header X-XSS-Protection "1; mode=block" always;

    location / {
        limit_req zone=advanced_limit burst=5 nodelay;

        if ($args ~* "(union|select|information_schema|sleep|benchmark|%27|%22)") {
            return 403;
        }

        proxy_pass http://webapp:80;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    }

    location /login {
        limit_req zone=advanced_limit burst=3 nodelay;

        proxy_pass http://webapp:80;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
    }
}
```


4.2.4 Detector d'atacs

El detector és un script Bash encarregat d'analitzar contínuament els logs generats per NGINX.

El sistema implementa detecció per:

- SQL Injection
- Brute Force
- Port Scanning

El detector funciona mitjançant:

1. Lectura incremental dels logs.
2. Aplicació de patrons Regex.
3. Comptatge de peticions sospitoses.
4. Generació d'alertes textuais.
5. Generació de registres JSON estructurats.

Les alertes JSON inclouen:

- Tipus d'atac
- IP origen
- Nivell de defensa
- Descripció
- Acció realitzada
- Riscos

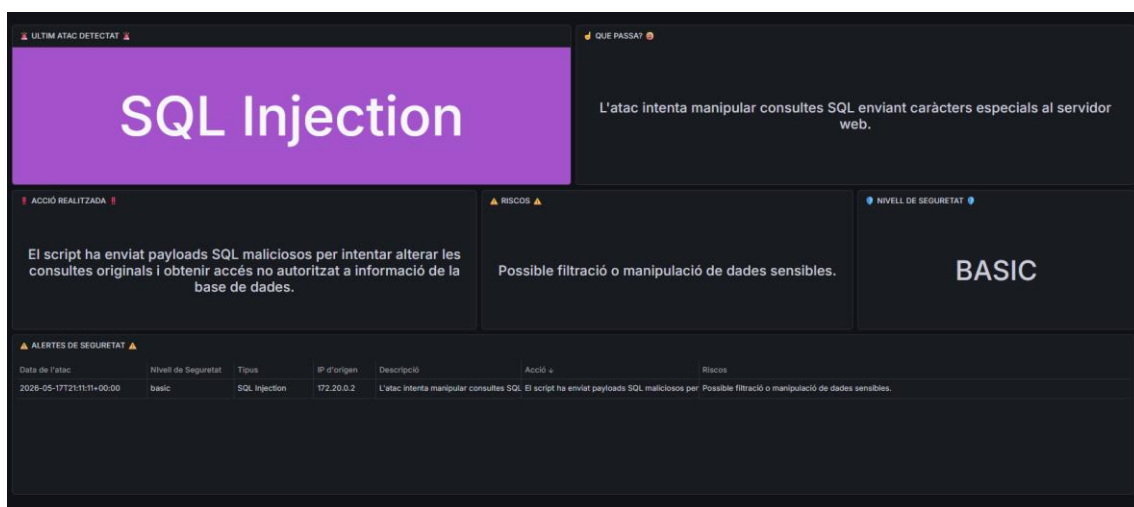
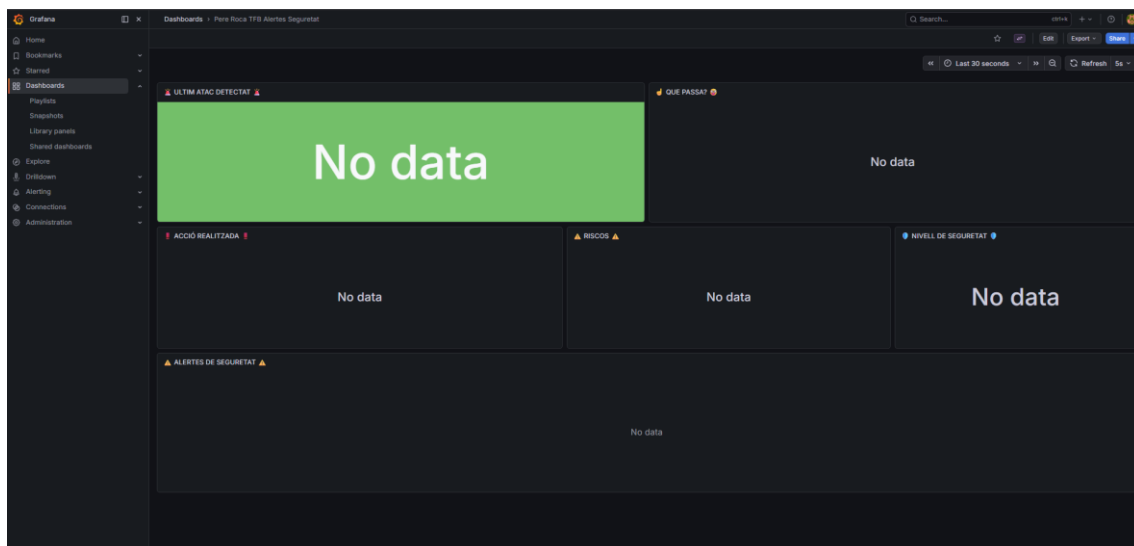
```
1 | detection.json | U.X | detectionlog | port-scanner | sql-injection | forga-brutash | default.com... | default.com... | default.com... | prometheus.yml | overview.json |
logs | | detection.json | > -
3 | ("timestamp": "2026-05-17T02:14:22:00.00", "security_level": "basic", "attack_type": "SQL Injection", "source_ip": "172.20.0.3", "description": "L'atac intenta manipular consultes SQL enviant caràcters especials al servidor web.", "script_action": "El script ha enviat payloads SQL maliciosos per intentar alterar les consultes originals i obtenir accés no autoritzat a informació de la base de dades.", "risk": "Possible filtració o manipulació de dades sensibles.", "detected": true)
4 | ("timestamp": "2026-05-17T02:14:22:00.00", "security_level": "basic", "attack_type": "Brute Force", "source_ip": "172.20.0.3", "description": "L'atac intenta accedir al sistema provant múltiples credencials consecutivament.", "script_action": "El script ha realitzat múltiples intents consecutius d'inici de sessió contra el formulari /login abans d'obtenir accés no autoritzat a informació de la base de dades.", "risk": "Possible compromís de comptes d'usuari.", "detected": true)
5 | ("timestamp": "2026-05-17T02:14:53:00.00", "security_level": "basic", "attack_type": "Port Scanning", "source_ip": "172.20.0.3", "description": "L'atac intenta identificar serveis i recursos actius al servidor.", "script_action": "El script ha enviat múltiples connexions ràpides (41) contra diferents serveis del servidor per identificar quins ports i aplicacions estan actius abans d'un possible atac posterior.", "risk": "Fase de reconeixement prèvia a possibles atacs més avançats.", "detected": true)
6 | ("timestamp": "2026-05-17T02:15:03:00.00", "security_level": "basic", "attack_type": "SQL Injection", "source_ip": "172.20.0.3", "description": "L'atac intenta manipular consultes SQL enviant caràcters especials al servidor web.", "script_action": "El script ha enviat payloads SQL maliciosos per intentar alterar les consultes originals i obtenir accés no autoritzat a informació de la base de dades.", "risk": "Possible filtració o manipulació de dades sensibles.", "detected": true)
7 | ("timestamp": "2026-05-17T02:15:10:00.00", "security_level": "basic", "attack_type": "Brute Force", "source_ip": "172.20.0.3", "description": "L'atac intenta accedir al sistema provant múltiples credencials consecutivament.", "script_action": "El script ha realitzat múltiples intents consecutius d'inici de sessió contra el formulari /login abans d'obtenir accés no autoritzat a informació de la base de dades.", "risk": "Possible compromís de comptes d'usuari.", "detected": true)
8 | ("timestamp": "2026-05-17T02:16:09:00.00", "security_level": "avancat", "attack_type": "Port Scanning", "source_ip": "172.20.0.3", "description": "L'atac intenta identificar serveis i recursos actius al servidor.", "script_action": "El script ha enviat múltiples connexions ràpides (50) contra diferents serveis del servidor per identificar quins ports i aplicacions estan actius abans d'un possible atac posterior.", "risk": "Fase de reconeixement prèvia a possibles atacs més avançats.", "detected": true)
9 | ("timestamp": "2026-05-17T02:16:29:00.00", "security_level": "avancat", "attack_type": "SQL Injection", "source_ip": "172.20.0.3", "description": "L'atac intenta manipular consultes SQL enviant caràcters especials al servidor web.", "script_action": "El script ha enviat payloads SQL maliciosos per intentar alterar les consultes originals i obtenir accés no autoritzat a informació de la base de dades.", "risk": "Possible filtració o manipulació de dades sensibles.", "detected": true)
10 | ("timestamp": "2026-05-17T02:16:30:00.00", "security_level": "avancat", "attack_type": "Port Scanning", "source_ip": "172.20.0.5", "description": "L'atac intenta identificar serveis i recursos actius al servidor.", "script_action": "El script ha enviat múltiples connexions ràpides (50) contra diferents serveis del servidor per identificar quins ports i aplicacions estan actius abans d'un possible atac posterior.", "risk": "Fase de reconeixement prèvia a possibles atacs més avançats.", "detected": true)
11 | ("timestamp": "2026-05-17T02:21:30:00.00", "security_level": "avancat", "attack_type": "Port Scanning", "source_ip": "172.20.0.5", "description": "S'ha detectat un patró de reconeixement de xarxa compatible amb tècniques automatitzades de descoberta de serveis.", "script_action": "El script ha generat múltiples connexions ràpides contra diferents serveis per identificar ports oberts i possibles punts vulnerables.", "risk": "Possible fase preparatòria abans d'un atac dirigit contra serveis exposats.", "detected": true)
12 | ("timestamp": "2026-05-17T02:21:35:00.00", "security_level": "avancat", "attack_type": "Port Scanning", "source_ip": "172.20.0.5", "description": "S'ha detectat un patró de reconeixement de
```

El detector implementa un model de processament incremental dels logs per evitar duplicacions i simular el comportament d'un IDS real.

4.2.5 Sistema de monitorització

El sistema de monitorització està format per Promtail, Loki i Grafana.

- **Promtail**
 - Promtail s'encarrega de llegir els fitxers de logs i enviar-los cap a Loki.
- **Loki**
 - Loki emmagatzema i indexa els logs generats pel detector.
- **Grafana**
 - Grafana mostra visualment:
 - Últim atac detectat
 - Explicació automàtica
 - Acció realitzada
 - Riscos associats
 - Estat general del sistema



La visualització dels atacs en temps real permet convertir esdeveniments tècnics complexos en informació accessible i comprensible per a estudiants.

4.3 Desenvolupament i execució

4.3.1 Entorn de desenvolupament

El desenvolupament del projecte s’ha realitzat en un entorn Ubuntu sobre WSL2 utilitzant Docker Desktop.

Les principals tecnologies utilitzades són:

Tecnologia	Funció
Docker	Contenidors
Docker Compose	Orquestració
Flask	Interfície web
Bash	Automatització
NGINX	Reverse Proxy
Grafana	Visualització
Loki	Logs
Promtail	Recol·lecció

```
PS C:\Users\Pere_Roca\Desktop\UNI\TERCERO\TFB> docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS                               NAMES
27f8b4ff7fb9   tfb-pereroca-reverse-proxy          "/docker-entrypoint..." 2 hours ago   Up 2 hours   0.0.0.0:8080->80/tcp, [::]:8080->80/tcp   reverse-proxy
dc680bc575bb   tfb-pereroca-attack-panel          "python app.py"           2 hours ago   Up 2 hours   0.0.0.0:5000->5000/tcp, [::]:5000->5000/tcp   attack-panel
b6f02159bb48   tfb-pereroca-webapp                "docker-php-entrypoi..." 2 hours ago   Up 2 hours   80/tcp                               webapp
c6eac5b0da23   tfb-pereroca-kali                  "/bin/bash"               2 hours ago   Up 2 hours                               kali
51bc18becf69   grafana/grafana:latest             "/run.sh"                 19 hours ago   Up 3 hours   0.0.0.0:3000->3000/tcp, [::]:3000->3000/tcp   grafana
8556af736c0c   grafana/loki:2.9.8                 "/usr/bin/loki -conf..." 19 hours ago   Up 3 hours   0.0.0.0:3100->3100/tcp, [::]:3100->3100/tcp   loki
cf137b8d66b0   prom/prometheus:latest             "/bin/prometheus --c..." 19 hours ago   Up 3 hours   0.0.0.0:9090->9090/tcp, [::]:9090->9090/tcp   prometheus
db424af55bf4   grafana/promtail:2.9.8             "/usr/bin/promtail -..." 19 hours ago   Up 3 hours                               promtail
f61afbb68879   alpine:latest                      "sh /scripts/detect ..." 19 hours ago   Up 3 hours                               detector
ad9c27e7d2e3   mariadb:11                          "docker-entrypoint.s..." 19 hours ago   Up 3 hours   3306/tcp                             db
6e6b9e605bec   jasonish/suricata:latest           "/docker-entrypoint..." 19 hours ago   Up 3 hours                               suricata
```

4.3.2 Execució del sistema

El sistema s'executa mitjançant Docker Compose.

La infraestructura desplega automàticament:

- Reverse proxy
- Aplicació vulnerable
- Detector
- Grafana
- Loki
- Promtail
- Attack Panel
- Contenidor Kali Linux

L'execució general es realitza amb:

```
docker compose up -d --build
```

Posteriorment:

- El menú web queda disponible.
- Els dashboards s'inicialitzen.
- El detector comença a monitoritzar els logs.

5 Proves

5.1 Definició

Per validar el correcte funcionament del sistema s'ha desenvolupat un conjunt de proves orientades a verificar:

- Execució dels scripts.
- Generació de logs.
- Detecció dels atacs.
- Integració amb Grafana.
- Funcionament dels nivells de defensa.
- Visualització pedagògica dels resultats.

Les proves s'han estructurat segons els requisits funcionals identificats durant l'anàlisi.

Prova 1 – SQL Injection

Element	Valor
Objectiu	Validar detecció SQL Injection
Entrada	Execució script sqli.sh
Resultat esperat	Generació alerta i dashboard

SQL Injection

Envia una petició amb patrons típics d'injecció SQL per comprovar si el sistema ho detecta.

Executar SQL Injection

ULTIM ATAC DETECTAT

SQL Injection

QUE PASSA?

S'ha detectat un payload SQL amb patrons OR/SELECT compatibles amb tècniques de bypass d'autenticació i extracció de dades.

ACCIÓ REALITZADA

El script ha intentat modificar la consulta SQL original injectant condicions sempre certes per accedir a informació restringida.

RISCOS

Possible compromís complet de la base de dades i exposició de dades sensibles.

NIVELL DE SEURETAT

AVANÇAT

ALERTES DE SEURETAT

Data de l'atac	Nivell de Seguretat	Tipus	IP d'origen	Descripció	Acció +	Riscos
2026-05-17T21:57:15+00:00	avançat	SQL Injection	172.20.0.4	S'ha detectat un payload SQL amb pat...	El script ha intentat modificar la consulta SQL o	Possible compromís complet de la base de dades i exposició de dades sen
2026-05-17T21:57:05+00:00	avançat	Brute Force	172.20.0.4	S'han detectat múltiples intents d'auten...	El script ha intentat descobrir credencials vàlids.	Possible compromís de comptes d'usuari i escalada d'accés.
2026-05-17T21:57:05+00:00	avançat	Port Scanning	172.20.0.4	S'ha detectat un patró de reconeixeme...	El script ha generat múltiples connexions ràpids.	Possible fase preparatòria abans d'un atac dirigit contra serveis exposats.

```
{
  "timestamp": "2026-05-17T21:57:15+00:00",
  "security_level": "avançat",
  "attack_type": "SQL Injection",
  "source_ip": "172.20.0.4",
  "description": "S'ha detectat un payload SQL amb patrons OR/SELECT compatibles amb tècniques de bypass d'autenticació i extracció de dades.",
  "script_action": "El script ha intentat modificar la consulta SQL original injectant condicions sempre certes per accedir a informació restringida.",
  "risk": "Possible compromís complet de la base de dades i exposició de dades sensibles.",
  "detected": true
}
```

Prova 2 – Brute Force

Element	Valor
Objectiu	Validar detecció Brute Force
Entrada	Execució bruteforce.sh
Resultat esperat	Detecció múltiples intents login

ULTIM ATAC DETECTAT

QUE PASSAT

Brute Force

S'han detectat múltiples intents d'autenticació consecutius (20) compatibles amb tècniques automatitzades de força bruta.

ACCIÓ REALITZADA

RISCOS

AVANÇAT

ALERTES DE SEGURETAT

Data de l'atac	Nivell de Seguretat	Tipus	IP d'origen	Descripció	Acció	Riscos
2026-05-17T22:03:06+00:00	avancat	Brute Force	172.20.0.4	S'han detectat múltiples intents d'atac. El script ha intentat descobrir credencials vàlides mitjançant múltiples peticions POST automatitzades contra el formulari de login.	Possible compromís de comptes d'usuari i escalada d'accés.	

```
{
  "timestamp": "2026-05-17T22:03:06+00:00",
  "security_level": "avancat",
  "attack_type": "Brute Force",
  "source_ip": "172.20.0.4",
  "description": "S'han detectat múltiples intents d'autenticació consecutius (20) compatibles amb tècniques automatitzades de força bruta.",
  "script_action": "El script ha intentat descobrir credencials vàlides mitjançant múltiples peticions POST automatitzades contra el formulari de login.",
  "risk": "Possible compromís de comptes d'usuari i escalada d'accés.",
  "detected": true
}
```

Prova 3 – Port Scanning

Element	Valor
Objectiu	Validar detecció Port Scanning
Entrada	Execució scanning.sh
Resultat esperat	Detecció patró reconeixement

ULTIM ATAC DETECTAT

QUE PASSAT

Port Scanning

S'ha detectat un patró de reconeixement de xarxa compatible amb tècniques automatitzades de descoberta de serveis.

ACCIÓ REALITZADA

RISCOS

AVANÇAT

ALERTES DE SEGURETAT

Data de l'atac	Nivell de Seguretat	Tipus	IP d'origen	Descripció	Acció	Riscos
2026-05-17T22:03:56+00:00	avancat	Port Scanning	172.20.0.4	S'ha detectat un patró de reconeixement. El script ha generat múltiples connexions ràpides (50) contra diferents serveis per identificar ports oberts i possibles punts vulnerables.	Possible fase preparatòria abans d'un atac dirigit contra serveis exposats.	

```
{
  "timestamp": "2026-05-17T22:03:56+00:00",
  "security_level": "avancat",
  "attack_type": "Port Scanning",
  "source_ip": "172.20.0.4",
  "description": "S'ha detectat un patró de reconeixement de xarxa compatible amb tècniques automatitzades de descoberta de serveis.",
  "script_action": "El script ha generat múltiples connexions ràpides (50) contra diferents serveis per identificar ports oberts i possibles punts vulnerables.",
  "risk": "Possible fase preparatòria abans d'un atac dirigit contra serveis exposats.",
  "detected": true
}
```

5.2 Avaluació de requisits

Les proves realitzades permeten validar que la solució compleix els requisits funcionals definits.

Els scripts d'atac generen correctament activitat sospitosa detectable pel sistema.

El detector és capaç de:

- Analitzar logs en temps real.
- Detectar patrons específics.
- Generar alertes estructurades.
- Integrar-se amb Grafana.

La infraestructura Docker garanteix:

- Aïllament dels components.
- Reproducció consistent.
- Facilitat de desplegament.

Els dashboards compleixen l'objectiu pedagògic del projecte mostrant informació visual, contextual i comprensible.

5.3 Avaluació d'objectius

Els resultats obtinguts validen que la plataforma desenvolupada compleix els objectius definits inicialment.

El projecte aconsegueix:

- Simular atacs reals.
- Detectar activitat sospitosa.
- Visualitzar els resultats en temps real.
- Facilitar l'aprenentatge de conceptes de ciberseguretat.
- Permetre diferents nivells de dificultat i protecció.

La combinació de Docker, Flask, Grafana i Loki ha permès construir un entorn modular, escalable i reutilitzable.

La plataforma desenvolupada transforma tècniques habituals de detecció d'intrusions en un entorn interactiu i educatiu orientat a l'aprenentatge pràctic de la ciberseguretat.